



MEDISECURE HEALTH SYSTEMS

Information Assurance and Security Management Plan



Air University, Aerospace and Aviation Campus, Kamra

Department of Computer Science

BS. Cyber Security

Information Assurance

Project Title	MediSecure Health Systems										
Group No.	03										
Semester	BS(CyS) – 3B (Fall 2025)										
Submitted By	<table> <tr> <td>Haleema Abid</td><td>245053</td></tr> <tr> <td>Marrij Ali Khan</td><td>245073</td></tr> <tr> <td>Hassan Raza</td><td>245065</td></tr> <tr> <td>Salman Nazar</td><td>245067</td></tr> <tr> <td>Kanzul Eman</td><td>245075</td></tr> </table>	Haleema Abid	245053	Marrij Ali Khan	245073	Hassan Raza	245065	Salman Nazar	245067	Kanzul Eman	245075
Haleema Abid	245053										
Marrij Ali Khan	245073										
Hassan Raza	245065										
Salman Nazar	245067										
Kanzul Eman	245075										
Date of Submission	31/12/2025										
Submitted To	Ms. Mahnoor Department of Computer Science, AACK										

Contents

1. Information Assurance Overview	4
2. Company Selection.....	4
2.1 Company Type:	4
2.2 Organization Name:	4
2.3 Company Size:.....	4
3. Company Description	4
3.1 Operational Locations	5
3.2 Customers & Stakeholders	5
3.3 Regulatory & Compliance Requirements	5
4. Upper Management and Governance Structure.....	5
5. Organizational Chart	6
6. Critical Business Functions	7
7. Asset Identification.....	7
7.1 Information Assets.....	7
7.2 Physical Assets	7
7.3 Software Assets	7
7.4 Human Assets	7
8. Identification of Critical Assets	8
9. Cost-Benefit Analysis	8
9.1 Annual Security Investment Costs: \$700,000.....	8
9.2 Potential Losses Without Information Assurance Controls: \$1,005,000.....	9
9.3 Financial Justification & Return on Investment	10
10. Risk Assessment	11
10.1 Identification of Threats	11
10.1.1 Ransomware Attacks	11
10.1.2 Data Breaches	11
10.1.3 Phishing Attacks	11
10.1.4 Insider Threats	11
10.1.5 System or Hardware Failure.....	11
10.1.6 Power Outages.....	11

10.1.7 Natural Disasters	11
10.2 Identification of Vulnerabilities	12
10.3 Risk Assessment Using Likelihood × Impact	12
10.3.1 Likelihood	12
10.3.2 Impact	12
10.4 Risk Table (Risk Matrix Results)	13
10.5 Risk Level Interpretation	13
10.6 Heat Map	14
10.7 Risk Mitigation Controls:	14
10.8 Summary of Risk Assessment	15
11. Security Policies	15
11.1 Information Security Policy	15
11.7 Policy Alignment with Information Assurance Objectives	16
12. Network Architecture Diagram	16
13. Contingency Planning	17
13.1 Contingency Planning Purpose	17
13.2 Threat Scenarios	17
13.3 Backup Strategy	18
13.4 Disaster Recovery Strategy	18
13.5 Business Continuity Measures	19
14. Conclusion	19

1. Information Assurance Overview

This document outlines the Information Assurance (IA) planning approach adopted by MediSecure Health Systems (MHS). The objective is to protect sensitive healthcare administrative data, manage organizational risks, establish effective governance, and ensure continuity of critical digital healthcare services, including employee data management, billing, and patient booking systems.

2. Company Selection

2.1 Company Type:

Healthcare Organization

2.2 Organization Name:

MediSecure Health Systems (MHS)

2.3 Company Size:

- **Employees:** 200
- **Locations:**
 - i. 1 Head Office
 - ii. 1 Operations Center
- **Annual Revenue:** Approx. USD 25-30 million
- **IT Infrastructure Scale:**
 - i. Centralized on-premise server room
 - ii. Cloud-hosted healthcare applications
 - iii. Approx. 300 endpoints (employee systems, admin terminals)

3. Company Description

MediSecure Health Systems (MHS) provides non-clinical healthcare support services to hospitals, clinics, and medical practices. The organization focuses on secure management of healthcare administrative data and systems, including:

- Employee data management systems
- Patient appointment and booking systems
- Billing and insurance processing platforms

- Medical records storage and access services

3.1 Operational Locations

- **Head Office:** Executive management and policy governance
- **Operations Center:** IT systems, support services, and data processing

3.2 Customers & Stakeholders

- Hospitals and clinics
- Healthcare administrators
- Employees and contractors
- Insurance providers
- Government and regulatory bodies

3.3 Regulatory & Compliance Requirements

- HIPAA (Health Insurance Portability and Accountability Act)
- Healthcare data privacy regulations
- Internal data governance and security standards

4. Upper Management and Governance Structure

4.1 Executive Roles & Responsibilities

Chief Executive Officer (CEO)

- Oversees organizational strategy
- Approves information security policies
- Final decision-maker during major security incidents

Chief Financial Officer (CFO)

- Manages financial operations and billing systems
- Allocates cybersecurity and compliance budgets
- Oversees financial risk exposure

Chief Information Security Officer (CISO)

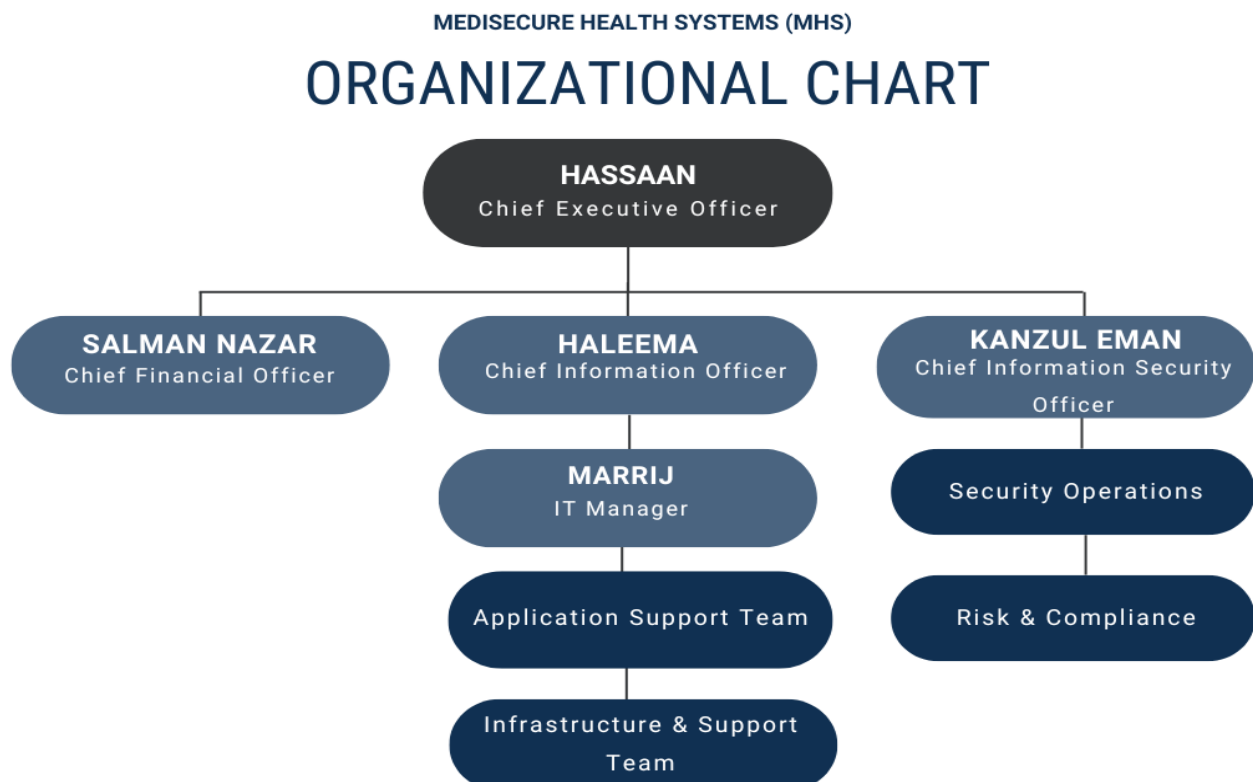
- Establishes information security policies
- Manages risk assessment and compliance
- Leads incident response efforts

Chief Information Officer (CIO)

- Oversees IT systems and application delivery
- Ensures secure and reliable service availability
- Works closely with the CISO

IT Manager

- Manages daily IT operations
- Maintains servers, networks, and backups
- Implements technical security controls

5. Organizational Chart

6. Critical Business Functions

Function	Why It Is Critical	Impact If Unavailable
Employee Data Management	Payroll & HR operations	Salary delays, compliance issues
Patient Booking System	Client healthcare operations	Appointment disruptions
Billing & Insurance Processing	Revenue generation	Financial loss
Records Management System	Legal & operational compliance	Regulatory penalties
Customer Support Services	Client satisfaction	Loss of trust and contracts

7. Asset Identification

7.1 Information Assets

- Employee personal and payroll data
- Patient appointment and billing records
- Client contracts and service data

7.2 Physical Assets

- Application servers
- Network devices (firewalls, switches)
- Backup storage systems

7.3 Software Assets

- Employee Management System (EMS)
- Patient Booking System (PBS)
- Billing and Insurance Processing System
- Databases and reporting tools

7.4 Human Assets

- IT administrators
- Billing and support staff

- Security and compliance personnel

8. Identification of Critical Assets

Critical Asset	Business Value	CIA Requirements	Business Impact
Billing System	Very High	High C, I, A	Revenue loss
Patient Booking System	High	High A, I	Client service disruption
Employee Data System	High	High C, I	Legal and privacy violations
Central Database	Very High	High C, I, A	Organization-wide failure

9. Cost-Benefit Analysis

9.1 Annual Security Investment Costs: \$700,000

9.1.1 Security Staff (\$280K)

- Healthcare companies with 200 employees require: one senior leader (\$110K–\$130K) and two operational staff (\$70K–\$90K each)
- Total staff cost: \$280,000

9.1.2 Security Tools & Software (\$150K)

- Industry standard: 1% of company revenue allocated to security tools
- MHS annual revenue: \$25-30 million
- 1% of revenue = \$250,000-\$300,000
- Conservative estimate used: \$150,000

9.1.3 Backup & Disaster Recovery Systems (\$120K)

- Contingency plan requires: cloud backups + warm site infrastructure
- Industry cost range for medium-sized organizations: \$80,000-\$150,000 annually

- Allocation: \$120,000

9.1.4 Employee Training, Compliance & Incident Response (\$110K)

- Security awareness training: \$175 per employee × 200 employees = \$35,000
- HIPAA compliance audits: \$75,000
- Incident response preparation: \$40,000

Total Annual IA Investment: ~\$700,000 (Approximately 2.3% of annual revenue)

9.2 Potential Losses Without Information Assurance Controls: \$1,005,000

9.2.1 Ransomware Attack (\$800,000 impact)

- Ransom payment: \$100,000-\$300,000
- System recovery costs: \$200,000-\$400,000
- Revenue loss during downtime: \$150,000-\$200,000
- Annual probability: 20% (healthcare sector experiences frequent attacks)
- **Expected annual loss: \$160,000**

9.2.2 Data Breach – Patient/Employee Records (\$1.2M impact)

- IBM Cost of Data Breach Report: Healthcare breaches average \$429 per compromised record
- Estimated exposed records: 2,000-3,000
- Legal and regulatory notification costs: \$200,000-\$300,000
- Annual probability: 15%
- **Expected annual loss: \$180,000**

9.2.3 System Downtime – 24-Hour Outage (\$500K impact)

- Billing system unavailability: \$150,000-\$200,000 lost revenue per day
- Operational disruption and manual workaround costs: \$300,000
- Annual probability: 25% (power failures, hardware malfunctions)
- **Expected annual loss: \$125,000**

9.2.4 HIPAA Regulatory Fines (\$600K impact)

- OCR enforcement penalties: \$100-\$50,000 per violation
- Typical non-compliance penalties: \$250,000-\$800,000
- Annual probability: 10% (periodic regulatory investigations)
- **Expected annual loss: \$60,000**

9.2.5 Phishing & Social Engineering Attacks (\$400K impact)

- Verizon DBIR: 45% of breaches involve social engineering
- Credential theft and unauthorized access costs: \$400,000
- Annual probability: 30% (most common attack vector)
- **Expected annual loss: \$120,000**

9.2.6 Loss of Client Contracts (\$2M impact)

- Major security incidents trigger client departures
- Loss of 1-2 major hospital/clinic contracts: \$1,000,000-\$2,000,000 in annual revenue
- Annual probability: 18% (reputation-damaging incidents)
- **Expected annual loss: \$360,000**

Total Annual Expected Loss Without IA Controls: \$1,005,000

9.3 Financial Justification & Return on Investment

9.3.1 Net Annual Benefit

- Expected losses prevented: \$1,005,000
- IA investment cost: \$700,000
- **Net benefit: \$305,000 per year**

Return on Investment (ROI)

- Calculation: $(\$305,000 \div \$700,000) \times 100 = 43.6\% \text{ ROI}$
- Meaning: For every dollar invested in security, MediSecure Health Systems saves \$1.44 in prevented losses

Conclusion: The financial analysis demonstrates that information assurance investments deliver substantial quantifiable returns. The 43.6% ROI and \$305,000 annual net benefit provide strong financial justification for robust security implementation at MediSecure Health Systems.

10.Risk Assessment

Risk assessment is performed to identify potential threats to the healthcare information system, analyze existing vulnerabilities, and evaluate risks based on their likelihood and impact on business operations and patient safety.

10.1 Identification of Threats

The following threats can negatively affect MediSecure Health System:

10.1.1 Ransomware Attacks

Malicious software that encrypts patient data and demands ransom.

10.1.2 Data Breaches

Unauthorized access to sensitive patient medical records.

10.1.3 Phishing Attacks

Deceptive emails targeting staff to steal credentials.

10.1.4 Insider Threats

Misuse of access privileges by employees or contractors.

10.1.5 System or Hardware Failure

Failure of servers, storage devices, or network equipment.

10.1.6 Power Outages

Loss of electricity affecting hospital IT systems.

10.1.7 Natural Disasters

Events such as floods, earthquakes, or fires damaging infrastructure.

10.2 Identification of Vulnerabilities

Vulnerabilities are weaknesses that threats can exploit.

Threat	Related Vulnerabilities
Ransomware	Unpatched systems, outdated antivirus
Data breach	Weak access control, shared accounts
Phishing	Low user security awareness
Insider threat	Excessive user privileges
System failure	Lack of redundancy
Power outage	Insufficient backup power
Natural disaster	Single data center location

10.3 Risk Assessment Using Likelihood × Impact

10.3.1 Likelihood

- Low (1): Rare occurrence
- Medium (2): Possible
- High (3): Likely

10.3.2 Impact

- Low (1): Minor disruption
- Medium (2): Operational impact
- High (3): Severe impact (patient safety, legal issues)

Risk Score = Likelihood × Impact

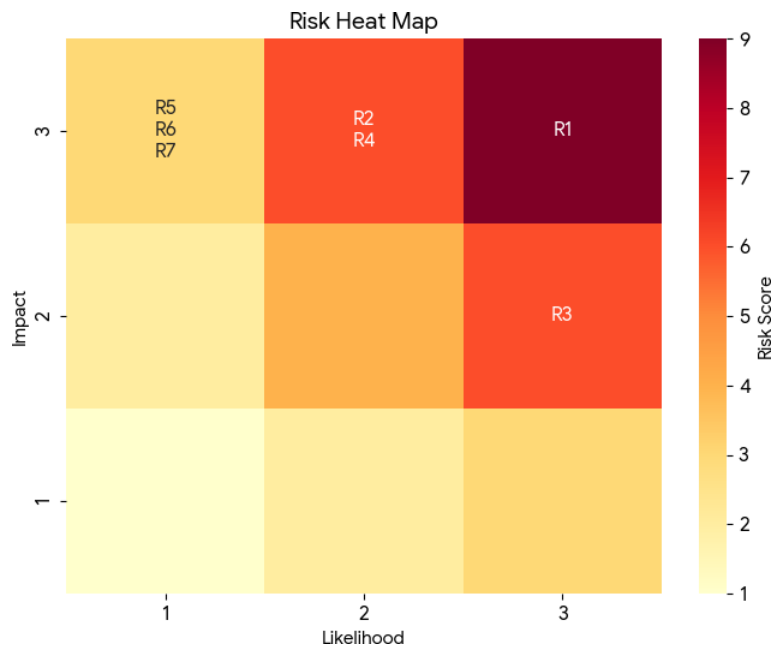
10.4 Risk Table (Risk Matrix Results)

Risk ID	Threat	Vulnerability	Likelihood	Impact	Risk Score	Risk Level
R1	Ransomware attack	Unpatched systems	3	3	9	High
R2	Data breach	Weak access control	2	3	6	High
R3	Phishing attack	Poor awareness	3	2	6	High
R4	Insider threat	Excess privileges	2	3	6	High
R5	System failure	No redundancy	1	3	3	Medium
R6	Power outage	Limited UPS	1	3	3	Medium
R7	Natural disaster	Single data center	1	3	3	Medium

10.5 Risk Level Interpretation

Risk Score	Risk Level	Description
1-2	Low	Acceptable risk
3-4	Medium	Requires monitoring
6-9	High	Immediate mitigation required

10.6 Heat Map



10.7 Risk Mitigation Controls:

Risk	Mitigation Controls
Ransomware	Regular patching, antivirus, offline backups
Data breach	Role-based access control, MFA, encryption
Phishing	Security awareness training, email filtering
Insider threat	Least privilege, access monitoring, audits
System failure	Redundant servers, regular maintenance
Power outage	UPS, backup generators
Natural disaster	Hot site, off-site backups

10.8 Summary of Risk Assessment

High risks are mainly related to cyber threats such as ransomware, phishing, data breaches, and insider misuse.

Medium risks are associated with infrastructure failures and environmental threats.

These risks require strong security controls, staff training, regular backups, and disaster recovery planning.

11. Security Policies

MediSecure Health Systems (MHS) implements the following key Information Assurance policies to protect organizational information assets and ensure secure delivery of healthcare administrative services.

11.1 Information Security Policy

Reference Frameworks: ISO/IEC 27001, ISO/IEC 27002

This policy establishes the overall information security objectives of MediSecure Health Systems (MHS). It aligns with ISO/IEC 27001 and ISO/IEC 27002 standards to ensure management commitment, risk-based security controls, and continuous improvement of information security practices.

11.2 Access Control Policy

Reference Framework: ISO/IEC 27001 (Annex A - Access Control)

This policy defines role-based access control (RBAC), user authentication, authorization, and access revocation procedures in alignment with ISO/IEC 27001 Annex A access control requirements.

11.3 Data Classification Policy

Reference Frameworks: ISO/IEC 27001, ISO/IEC 27002 (Information Classification)

This policy classifies organizational data into public, internal, and confidential categories and defines handling requirements in accordance with ISO/IEC standards.

11.4 Acceptable Use Policy

Reference Framework: ISO/IEC 27002 (Acceptable Use of Assets)

This policy defines acceptable and prohibited use of IT assets to reduce misuse, malware infections, and data leakage risks.

11.5 Incident Response Policy

Reference Framework: ISO/IEC 27035

This policy establishes procedures for identifying, reporting, responding to, and recovering from information security incidents, following ISO/IEC 27035 guidelines.

11.6 Backup and Recovery Policy

Reference Frameworks: ISO/IEC 27001, NIST SP 800-34

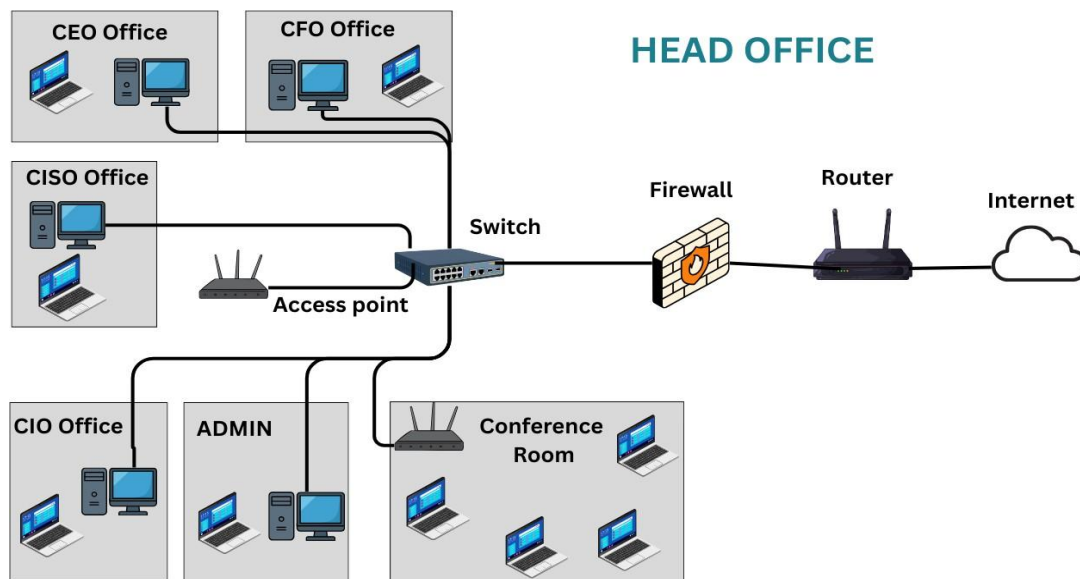
This policy defines backup, recovery, and disaster recovery requirements to ensure data availability and business continuity during system failures or disasters.

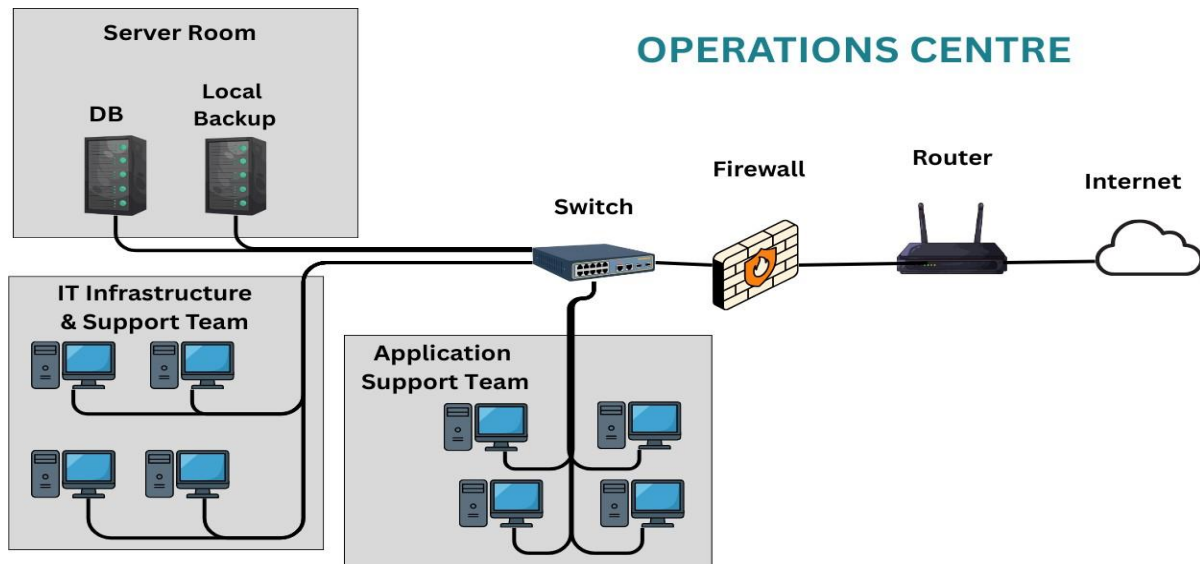
11.7 Policy Alignment with Information Assurance Objectives

Together, these policies support the core principles of Confidentiality, Integrity, and Availability (CIA) by:

- Preventing unauthorized access to sensitive data
- Ensuring accuracy and reliability of information
- Maintaining system and data availability during disruptions

12. Network Architecture Diagram





13. Contingency Planning

Contingency planning ensures that MediSecure Health Systems (MHS) can continue providing critical healthcare administrative services such as employee data management, billing, and patient booking systems during unexpected disruptions.

13.1 Contingency Planning Purpose

The primary objectives of contingency planning are:

- To ensure continuity of critical healthcare administrative services
- To minimize data loss, financial loss, and service downtime
- To protect sensitive employee and patient-related information
- To enable quick recovery of IT systems after an incident
- To define clear roles and responsibilities during emergencies

Effective contingency planning reduces operational risks and supports regulatory compliance.

13.2 Threat Scenarios

The organization has identified the following potential threat scenarios:

i. Cyberattack

Cyber threats such as ransomware, phishing, and malware attacks may disrupt billing systems, booking platforms, or compromise sensitive data.

ii. Power Failure

Unexpected power outages can cause system shutdowns, data corruption, and service unavailability, especially in on-premise server environments.

iii. Natural Disaster

Events such as floods, fires, or earthquakes may damage physical infrastructure, including servers and networking equipment.

iv. System Failure

Hardware malfunctions, software crashes, or database failures may interrupt employee management, billing, or booking services.

13.3 Backup Strategy

To ensure data availability and integrity, MediSecure Health Systems (MHS) follows a structured backup strategy:

- **Backup Types:**
 - **Full Backups:** Complete system and database backups
 - **Incremental Backups:** Backup of data changed since the last backup
- **Backup Frequency:**
 - Full backups performed weekly
 - Incremental backups performed daily
- **Storage Location:**
 - Encrypted off-site cloud storage
 - Secondary local backup for critical systems

This strategy ensures rapid data restoration while minimizing data loss.

13.4 Disaster Recovery Strategy

The disaster recovery plan focuses on restoring IT services within acceptable timeframes:

- **Recovery Time Objective (RTO):**
 - Maximum acceptable downtime is 6 hours
- **Recovery Point Objective (RPO):**
 - Maximum acceptable data loss is 2 hours
- **Alternate Site:**
 - Cloud-based warm site that maintains updated system images and data backups
 - Allows faster recovery than a cold site with lower cost than a hot site

This approach balances cost, recovery speed, and operational requirements.

13.5 Business Continuity Measures

To maintain operations during incidents, the following continuity measures are in place:

- **Manual Procedures**
 - Manual employee data entry and record keeping
 - Offline appointment scheduling and billing documentation
 - Temporary use of spreadsheets or paper-based forms
- **Communication Plan**
 - Immediate incident notification to management and IT staff
 - Email and phone communication with employees and clients
 - Status updates provided to customers regarding service restoration
- **Staff Roles During Incidents**
 - **CISO:** Leads incident response and security decisions
 - **CIO / IT Manager:** Manages system recovery and technical response
 - **Operations Staff:** Execute manual business procedures
 - **Management:** Approves critical decisions and communicates externally

14. Conclusion

MediSecure Health Systems (MHS) demonstrates a strong and well-structured information assurance posture suitable for a medium-sized healthcare services organization. The company has clearly defined governance roles, identified critical information assets, and implemented appropriate security policies to protect sensitive employee, billing, and patient booking data.

The key risks identified include cyberattacks such as ransomware and phishing, potential data breaches due to unauthorized access, and system downtime caused by power or hardware failures. These risks pose serious operational, financial, and compliance challenges if not properly managed.

Information assurance planning is critical for MediSecure Health Systems (MHS) because the organization handles sensitive healthcare-related data and provides essential administrative services to healthcare providers. Effective IA planning ensures confidentiality, integrity, and availability (CIA) of information, supports regulatory compliance, minimizes business disruption, and maintains trust with clients and stakeholders.